



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report-Fixed-taskmanager

Site: <http://127.0.0.1:8000>

Generated on Sat, 9 May 2026 12:43:13

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	5
Informational	5

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap. log file for details	5
Low	Warning		ZAP warnings logged - see the zap. log file for details	2
Info	Informational	http://127.0.0.1:8000	Percentage of responses with status code 2xx	59 %
Info	Informational	http://127.0.0.1:8000	Percentage of responses with status code 3xx	6 %
Info	Exceeded Low	http://127.0.0.1:8000	Percentage of responses with status code 4xx	34 %
Info	Informational		Percentage of endpoints with	2 %

		http://127.0.0.1:8000	content type image/png	
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with content type text/css	17 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with content type text/html	54 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with content type text/javascript	26 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with method GET	93 %
Info	Informational	http://127.0.0.1:8000	Percentage of endpoints with method POST	6 %
Info	Informational	http://127.0.0.1:8000	Count of total endpoints	46
Info	Informational	http://127.0.0.1:8000	Percentage of slow responses	1 %

Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	Medium	2
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Sub Resource Integrity Attribute Missing	Medium	Systemic
Vulnerable JS Library	Medium	2
Cookie No HttpOnly Flag	Low	3
Cookie without SameSite Attribute	Low	3
Cross-Domain JavaScript Source File Inclusion	Low	Systemic
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic

Authentication Request Identified	Informational	1
Cookie Poisoning	Informational	1
Information Disclosure - Suspicious Comments	Informational	26
Session Management Response Identified	Informational	3
User Controllable HTML Element Attribute (Potential XSS)	Informational	1

Alert Detail

Medium	Absence of Anti-CSRF Tokens
Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL /form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: * The victim has an active session on the target site. * The victim is authenticated via HTTP auth on the target site. * The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.
URL	http://127.0.0.1:8000/taskManager/forgot_password/
Node Name	http://127.0.0.1:8000/taskManager/forgot_password/
Method	GET
Attack	
Evidence	<form method="post" role="form">
Other Info	No known Anti-CSRF token [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "email"].
URL	http://127.0.0.1:8000/taskManager/forgot_password/
Node Name	http://127.0.0.1:8000/taskManager/forgot_password/()(email)
Method	POST
Attack	
Evidence	<form method="post" role="form">
Other Info	No known Anti-CSRF token [anticsrf, CSRFTOKEN, __RequestVerificationToken, csrfmiddlewaretoken, authenticity_token, OWASP_CSRFTOKEN, anoncsrf, csrf_token, _csrf, _csrfSecret, __csrf_magic, CSRF, _token, _csrf_token, _csrfToken] was found in the following HTML form: [Form 1: "email"].

Instances	2
Solution	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330). Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html
CWE Id	352
WASC Id	9
Plugin Id	10202

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	
Other Info	

URL	http://127.0.0.1:8000/robots.txt
Node Name	http://127.0.0.1:8000/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:8000/sitemap.xml
Node Name	http://127.0.0.1:8000/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:8000/static/taskManager/js/bootstrap.min.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/bootstrap.min.js
Method	GET
Attack	
Evidence	
Other Info	
URL	http://127.0.0.1:8000/taskManager/tutorials/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038
Medium	Sub Resource Integrity Attribute Missing

Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="http://fonts.googleapis.com/css?family=PT+Sans:300,400,400 italic,700" >
Other Info	
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="http://fonts.googleapis.com/css?family=Ubuntu:300,400,400 italic,700" >
Other Info	
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	
Evidence	<link rel="stylesheet" href="http://fonts.googleapis.com/css?family=PT+Sans:300,400,400 italic,700" >
Other Info	
URL	http://127.0.0.1:8000/taskManager/tutorials/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
Instances	Systemic

Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
CWE Id	345
WASC Id	15
Plugin Id	90003

Medium	Vulnerable JS Library
Description	The identified library appears to be vulnerable.
URL	http://127.0.0.1:8000/static/taskManager/js/bootstrap.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/bootstrap.js
Method	GET
Attack	
Evidence	* Bootstrap v3.2.0
Other Info	The identified library bootstrap, version 3.2.0 is vulnerable. CVE-2018-14041 CVE-2019-8331 CVE-2018-14040 CVE-2018-20677 CVE-2018-20676 CVE-2018-14042 CVE-2016-10735 CVE-2024-6485 https://nvd.nist.gov/vuln/detail/CVE-2024-6485 https://github.com/twbs/bootstrap/issues/28236 https://www.herodevs.com/vulnerability-directory/cve-2024-6485 https://github.com/advisories/GHSA-pj7m-g53m-7638 https://github.com/twbs/bootstrap/issues/20184 https://github.com/advisories/GHSA-vxmc-5x29-h64v https://github.com/advisories/GHSA-ph58-4vrj-w6hr https://github.com/twbs/bootstrap https://github.com/twbs/bootstrap/issues/20631 https://github.com/advisories/GHSA-4p24-vmcr-4ggj https://github.com/advisories/GHSA-9v3m-8fp8-mj99 https://nvd.nist.gov/vuln/detail/CVE-2018-20676
URL	http://127.0.0.1:8000/static/taskManager/js/jquery-1.8.3.min.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/jquery-1.8.3.min.js
Method	GET

Attack	
Evidence	jquery-1.8.3.min.js
Other Info	The identified library jquery, version 1.8.3 is vulnerable. CVE-2020-11023 CVE-2020-11022 CVE-2015-9251 CVE-2019-11358 CVE-2020-7656 CVE-2012-6708 https://nvd.nist.gov/vuln/detail/CVE-2012-6708 https://github.com/jquery/jquery/issues/2432 http://research.insecurelabs.org/jquery/test/ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 https://github.com/advisories/GHSA-rmxg-73gg-4p98 https://bugs.jquery.com/ticket/11974 https://github.com/jquery/jquery.com/issues/162 https://nvd.nist.gov/vuln/detail/CVE-2020-7656 http://blog.jquery.com/2016/01/08/jquery-2-2-and-1-12-released/ http://bugs.jquery.com/ticket/11290 https://research.insecurelabs.org/jquery/test/ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ https://nvd.nist.gov/vuln/detail/CVE-2015-9251 https://github.com/advisories/GHSA-q4m3-2j7h-f7xw https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/
Instances	2
Solution	Upgrade to the latest version of the affected library.
Reference	https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/
CWE Id	1395
WASC Id	
Plugin Id	10003
Low	Cookie No HttpOnly Flag
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://127.0.0.1:8000/taskManager/login/
Node	

Name	http://127.0.0.1:8000/taskManager/login/
Method	GET
Attack	
Evidence	Set-Cookie: csrftoken
Other Info	
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	
Evidence	Set-Cookie: csrftoken
Other Info	
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/ ()(csrftoken,password,username)
Method	POST
Attack	
Evidence	Set-Cookie: csrftoken
Other Info	
Instances	3
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	Cookie without SameSite Attribute
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/
Method	GET
Attack	
Evidence	Set-Cookie: csrftoken
Other Info	
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	

Evidence	Set-Cookie: csrftoken
Other Info	
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/()(csrfmiddlewaretoken,password,username)
Method	POST
Attack	
Evidence	Set-Cookie: csrftoken
Other Info	
Instances	3
Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	Cross-Domain JavaScript Source File Inclusion
Description	The page includes one or more script files from a third-party domain.
URL	http://127.0.0.1:8000/
Node Name	http://127.0.0.1:8000/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
URL	http://127.0.0.1:8000/taskManager/tutorials/
Node	

Name	http://127.0.0.1:8000/taskManager/tutorials/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
URL	http://127.0.0.1:8000/taskManager/tutorials/injection/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/injection/
Method	GET
Attack	
Evidence	<script src="http://html5shim.googlecode.com/svn/trunk/html5.js"></script>
Other Info	
Instances	Systemic
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	Server Leaks Version Information via "Server" HTTP Response Header Field
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://127.0.0.1:8000/static/taskManager/css/font-awesome.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/font-awesome.css
Method	GET
Attack	
Evidence	WSGIServer/0.2 CPython/3.8.18
Other Info	
URL	http://127.0.0.1:8000/static/taskManager/css/railscasts.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/railscasts.css
Method	GET
Attack	
Evidence	WSGIServer/0.2 CPython/3.8.18
Other Info	
URL	http://127.0.0.1:8000/static/taskManager/css/style.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/style.css
Method	GET

Attack	
Evidence	WSGIServer/0.2 CPython/3.8.18
Other Info	
URL	http://127.0.0.1:8000/static/taskManager/img/logo_lg.png
Node Name	http://127.0.0.1:8000/static/taskManager/img/logo_lg.png
Method	GET
Attack	
Evidence	WSGIServer/0.2 CPython/3.8.18
Other Info	
URL	http://127.0.0.1:8000/taskManager/login
Node Name	http://127.0.0.1:8000/taskManager/login
Method	GET
Attack	
Evidence	WSGIServer/0.2 CPython/3.8.18
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://127.0.0.1:8000/static/taskManager/css/backend/bootstrap-reset.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/backend/bootstrap-reset.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/static/taskManager/css/font-awesome.css

Node Name	http://127.0.0.1:8000/static/taskManager/css/font-awesome.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/static/taskManager/css/railscasts.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/railscasts.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/static/taskManager/css/style.css
Node Name	http://127.0.0.1:8000/static/taskManager/css/style.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://127.0.0.1:8000/static/taskManager/img/logo_lg.png
Node Name	http://127.0.0.1:8000/static/taskManager/img/logo_lg.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)

	https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Authentication Request Identified
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/ ()(csrfmiddlewaretoken,password,username)
Method	POST
Attack	
Evidence	password
Other Info	userParam=username userValue=ZAP passwordParam=password referer=http://127.0.0.1:8000/taskManager/login/ csrfToken=csrfmiddlewaretoken
Instances	1
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
CWE Id	
WASC Id	
Plugin Id	10111

Informational	Cookie Poisoning
Description	This check looks at user-supplied input in query string parameters and POST data to identify where cookie parameters might be controlled. This is called a cookie poisoning attack, and becomes exploitable when an attacker can manipulate the cookie in various ways. In some cases this will not be exploitable, however, allowing URL parameters to set cookie values is generally considered a bug.
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/ ()(csrfmiddlewaretoken,password,username)
Method	POST
Attack	
Evidence	
Other	An attacker may be able to poison cookie values through POST parameters. To test if this is a more serious issue, you should try resending that request as a GET, with the POST parameter included as a query string parameter. For example: https://nottrusted.com/page?value=maliciousInput. This was identified at: http://127.0.0.1:8000/taskManager/login/

Info	User-input was found in the following cookie: csrftoken=fBk0sNGAURHmFx8cEJy6sl5tPhhwgkeg; expires=Sat, 08-May-2027 09:41:57 GMT; Max-Age=31449600; Path=/ The user input was: csrfmiddlewaretoken=fBk0sNGAURHmFx8cEJy6sl5tPhhwgkeg
Instances	1
Solution	Do not allow user input to control cookie names and values. If some query string parameters must be set in cookie values, be sure to filter out semicolon's that can serve as name/value pair delimiters.
Reference	https://en.wikipedia.org/wiki/HTTP_cookie https://cwe.mitre.org/data/definitions/565.html
CWE Id	565
WASC Id	20
Plugin Id	10029

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.dcjaccordion.2.7.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.dcjaccordion.2.7.js
Method	GET
Attack	
Evidence	// create array from cookie string
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// // create array from cookie string", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Method	GET
Attack	
Evidence	/** * User option handler
Other Info	The following pattern was used: \bUSER\b and was detected 2 times, the first in likely comment: "/*" * User option handler */", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Method	GET
Attack	
Evidence	// XXX This should probabl
Other Info	The following pattern was used: \bXXX\b and was detected in likely comment: "// XXX This should probably be a configurable option", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Node	

Name	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Method	GET
Attack	
Evidence	e object and id for later rendering
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "/* * Generate a shape object and id for later rendering */", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/jquery.sparkline.js
Method	GET
Attack	
Evidence	ne sparkline charts from data supplied eithe
Other Info	The following pattern was used: \bFROM\b and was detected 5 times, the first in likely comment: "/* * * jquery.sparkline.js * * v2.1.2 * (c) Splunk, Inc * Contact: Gareth Watts (gareth@splunk.com) * http://omnipotent.net/jqu", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/respond.min.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/respond.min.js
Method	GET
Attack	
Evidence	st a CSS media type/query in JS. Authors & co
Other Info	The following pattern was used: \bQUERY\b and was detected 2 times, the first in likely comment: "/*! matchMedia() polyfill - Test a CSS media type/query in JS. Authors & copyright (c) 2012: Scott Jehl, Paul Irish, Nicholas Za", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/slidebars.min.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/slidebars.min.js
Method	GET
Attack	
Evidence	// 003 - User Agents
Other Info	The following pattern was used: \bUSER\b and was detected 14 times, the first in likely comment: "// 003 - User Agents", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/slidebars.min.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/slidebars.min.js

Method	GET
Attack	
Evidence	also stop Slidebars from opening.
Other Info	The following pattern was used: \bFROM\b and was detected 3 times, the first in likely comment: "// false stop Slidebars from opening.", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Method	GET
Attack	
Evidence	Also fixes browser bugs compared to the nat
Other Info	The following pattern was used: \bBUGS\b and was detected 10 times, the first in likely comment: "/* * Executes a regex search in a specified string. Returns a match array or `null`. If the provided * regex uses named captu", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Method	GET
Attack	
Evidence	, while freeing you from * worrying about p
Other Info	The following pattern was used: \bFROM\b and was detected 7 times, the first in likely comment: "/* * XRegExp provides augmented, extensible JavaScript regular expressions. You get new syntax, * flags, and methods beyond w", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Method	GET
Attack	
Evidence	// Fixes IE, Safari bug (last tested IE 9,
Other Info	The following pattern was used: \bBUG\b and was detected 6 times, the first in likely comment: "// Fixes IE, Safari bug (last tested IE 9, Safari 5.1)", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Method	GET
Attack	
Evidence	The regex scope where the match was found
	The following pattern was used: \bWHERE\b and was detected 2 times, the first in likely comment: "/*

Other Info	* Extends or changes XRegExp syntax and allows custom flags. This is used internally and can be * used to create XRegExp a", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/backend/xregexp.js
Method	GET
Attack	
Evidence	ny character with a later instance in the str
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "// Any character with a later instance in the string", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/static/taskManager/js/bootstrap.js
Node Name	http://127.0.0.1:8000/static/taskManager/js/bootstrap.js
Method	GET
Attack	
Evidence	// detach from parent, fire event
Other Info	The following pattern was used: \bFROM\b and was detected in likely comment: "// detach from parent, fire event then clean up data", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	
Evidence	r can log into this admin site.</td></
Other Info	The following pattern was used: \bADMIN\b and was detected in likely comment: "<!--<tr><th><label for='id_password'>Password:</label></th><td><input id='id_password' maxlength='128' name='password' type='te", see evidence field for the suspicious comment/snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/access/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/access/
Method	GET
Attack	
Evidence	<!--search & user info start-->

Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/brokenauth/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/brokenauth/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/components/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/components/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/csrf/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/csrf/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/exposure/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/exposure/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/idor/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/idor/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.

URL	http://127.0.0.1:8000/taskManager/tutorials/injection/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/injection/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/misconfig/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/misconfig/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/redirects/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/redirects/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
URL	http://127.0.0.1:8000/taskManager/tutorials/xss/
Node Name	http://127.0.0.1:8000/taskManager/tutorials/xss/
Method	GET
Attack	
Evidence	<!--search & user info start-->
Other Info	The following pattern was used: \bUSER\b and was detected 3 times, the first in likely comment: "<!--search & user info start-->", see evidence field for the suspicious comment /snippet.
Instances	26
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	Session Management Response Identified
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based

	Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/
Method	GET
Attack	
Evidence	csrftoken
Other Info	cookie:csrftoken
URL	http://127.0.0.1:8000/taskManager/register/
Node Name	http://127.0.0.1:8000/taskManager/register/
Method	GET
Attack	
Evidence	csrftoken
Other Info	cookie:csrftoken
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/ ()(csrftoken,password,username)
Method	POST
Attack	
Evidence	csrftoken
Other Info	cookie:csrftoken
Instances	3
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
CWE Id	
WASC Id	
Plugin Id	10112

Informational	User Controllable HTML Element Attribute (Potential XSS)
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://127.0.0.1:8000/taskManager/login/
Node Name	http://127.0.0.1:8000/taskManager/login/ ()(csrftoken,password,username)
Method	POST
Attack	
Evidence	
	User-controlled HTML attribute values were found. Try injecting special characters to see if XSS might be possible. The page at the following URL:

Other Info	http://127.0.0.1:8000/taskManager/login/ appears to include user input in: a(n) [input] tag [value] attribute The user input found was: csrfmiddlewaretoken=fBk0sNGAURHmFx8cEJy6sl5tPhhwgkeg The user-controlled value was: fbk0sngaurhmf8cejy6sl5tphhwgkeg
Instances	1
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
CWE Id	20
WASC Id	20
Plugin Id	10031